MyPlatform: design brief for a stress test

MyPlatform: design brief for a stress test

You are reviewing MyPlatform, a private, invitation-only platform for brokers, intermediaries and principals in physical commodity markets. Your job is to find weaknesses, redundant parts, gaps and improvements. Please read the whole brief before answering.

Every fact below comes from the repository. Where a reason is not written down anywhere, this brief says “reason not recorded”. Please treat “reason not recorded” as an invitation to challenge, not as a fact.

Sources used: `CLAUDE.md`, `HANDOFF.md`, `docs/CHECKLIST.md`, `docs/AGREED-2026-10-25.md`, `docs/AGREED-2026-10-28-cloudflare.md`, `docs/AGREED-2026-11-01-owner-changes.md`, `docs/TERMS-3.6-full.md`, `sql/`, `app.html`, `operator.html`, `js/`, `.github/workflows/`. The external Terms reviews are on the branch `claude/great-allen-5xl0gm` under `docs/terms-reviews/`.

---

1. The business concept

What it is. A members-only market where a member posts an opportunity to buy or sell a physical commodity. Other members can see the opportunity, but not who posted it. Contact goes through a single human intermediary, called the Operator. The Operator relays messages, decides what is passed on, and makes introductions.

Why it was built this way. The reason is written in the decisions. The Terms say the Operators act as brokers and intermediaries and may act for both sides of the same transaction (`docs/AGREED-2026-10-25.md`, item 1; `terms.s1`). Section 1 also says they read what participants send “in order to protect anonymity and decide what is passed on”. So the design rests on two ideas. First, anonymity is protected by a go-between. Second, the go-between is paid for introductions, and the commission has to be agreed before an introduction is made.

Commission before introduction. Section 8 of the Terms says the introductions are the Operators’ work and have commercial value. The commission is not fixed in the Terms, because the decisions say “some commodities pay” different amounts (`docs/AGREED-2026-10-25.md`, item 2). Its details are agreed in writing with the

party who pays it, before the introduction is made (`docs/AGREED-2026-10-25.md`, deal files section). The film script adds that direct access between the parties is granted only after the commission agreement is executed (`docs/films-2026-11/member-en-script.md`, commit `6f0e419` on `claude/great-allen-5xl0gm`).

Invitation only. Access is by invitation. The Operator creates an invitation, and the person registers, then waits to be approved (`HANDOFF.md`; `docs/CHECKLIST.md` items 01, 03, 04, 56). The reason recorded is that the Terms say “Access is granted solely at the Operators’ discretion” (`terms.s2`).

Explicitly not built. `HANDOFF.md` lists four things as deliberately not built: file upload or document exchange; direct member-to-member messaging (“central to the model, not an oversight”); automatic listing expiry; and automatic introductions (“never an automatic connection”).

---

2. The actors and what they can and cannot do

Member. Signs in after approval. Posts listings. Browses other listings. Contacts a listing through the Operator. Saves searches and watchlists. Keeps a mailbox of their own conversations. Downloads their own activity as a CSV.

- A member is a buyer, a seller or a broker. The listing records a role: principal, mandated intermediary, or broker (`docs/AGREED-2026-10-25.md`, item 16).
- The poster and the contacting member are different roles. The poster is anonymous to the other side. The contacting member’s identity is known only to the Operator.
- A member cannot read a scorecard, deal files, the Operator’s analytics or other members’ saved searches (`docs/CHECKLIST.md` items 24, 43, 71, 73).
- A member cannot change their own role or status (item 11), and cannot edit or withdraw another member’s listing (item 16).

The Operator. A single human role that holds the console. The Operator approves registrations, invites people, relays and edits messages, makes introductions, keeps deal files, and sees the activity log and figures.

- The Operator never requests a document, and sees no document answer on a listing (`docs/CHECKLIST.md` item 32; `docs/AGREED-2026-11-01-owner-changes.md`, decision 36). The Operator sees neither the document requests tab nor a Documents column (the change is in PR #80, merged).
- The Operator cannot read members’ saved searches (item 25).
- The Operator is emailed each time a member sends a message, but the email carries none of the message text (item 79, sql 047). Test accounts send no such email (the same marker as sql 027).
- Reason for the email: decision 39 of the owner’s batch, “never the message content” (`docs/AGREED-2026-11-01-owner-changes.md`). Reason for no content: not recorded beyond “never the message content”.

Test accounts. Accounts created by the test suite use the reserved domains `example.invalid`, `example.com`, `example.org`, `example.net`, or the prefix `jericho-e2e-`. The reserved domains are used because RFC 2606 says they can never be delivered (`sql/027_purge_test_mail.sql`). The same marker is used to exclude test accounts from the Operator email (sql 047) and from the receipt email (sql 048, on branch `receipt-email-terms`).

---

3. The member side, screen by screen

Sign-in and invitation. Invitation link, then registration, then the Terms, then pending approval. A pending member cannot sign in (item 06). A member who has not signed the newest Terms is held at sign-in until they sign (item 62). The welcome page is shown once, at first sign-in, in the member's language (item 77, sql 044).

Terms gate and re-signing. Each Terms version is stored in `terms_versions` and signed into `terms_acceptances`. The signing record holds the name typed as signature, the capacity (individual or company), the postal address, and a copy of the details at signing. The acceptance survives deletion of the member (item 63, decision 5 of 2026-10-25). Reason: the record must outlive the account.

New Listing. Fields: buy or sell, commodity, quantity and unit, specification, incoterm, origin, destination, price conditions, currency, price unit, notes. Then the member states their role. Then two document questions (have you seen the documents; can they be shown on request). Then a truth tick, stamped with the server's time (items 66, 69). Reason for the two-degrees rule: "An offer more than two steps from the principal is never accepted" (item 67; decision 17, `docs/AGREED-2026-10-25.md`).

Documents on a listing. A member declares which documents they hold, against a checklist (item 31). Nothing is uploaded or stored (item 33). Reason: `HANDOFF.md` "Deliberately not built": files are never uploaded or stored, because adding storage, scanning and access control is new work.

Browse. Lists other members' listings with filters and search. It shows the poster's role and one documents line. It never shows the mandate or the chain (items 18, 19, 20, 68). Per `HANDOFF.md`, Browse hides exactly one thing: the poster's identity. The fields `specification`, `price_conditions` and `notes` are returned as written (`docs/CHECKLIST.md`, open questions, item 20). Whether origin should be coarsened is an open product decision.

Contact. A member presses Contact on a listing, writes a message, and sends it. The message goes to the Operator. The owner of the listing never receives a message directly (item 26).

Mailbox. Shows only the member's own conversations (item 30). Replies from the Operator arrive here.

Renew and withdraw. A stale listing prompts its owner, who can renew it in one action (item 37). A member cannot fake how fresh a listing is (item 38), and cannot renew another member's listing (item 39). `HANDOFF.md` records only a 30-day reminder and a manual nudge; automatic expiry was deliberately not built. The reason is not recorded beyond that.

Export. A member downloads their own activity as CSV (item 34). It contains only the member's own data (item 35) and never names a counterparty (item 36).

Help. Sixteen questions in English and Spanish, before sign-in and inside the platform (item 76, `js/help.js`). The question about document requests was removed when the document requests were removed (decision 36).

Profile. A member updates their own contact details (item 10), changes email only with the current password and confirmation (item 12), and changes password only with the current password (item 13). The email change is noted in `HANDOFF.md` as needing a

confirmation the project does not send, which is a known gap.

Language. The whole interface switches between English and Spanish, and every list redraws (item 47). Emails go in the recipient's own language (item 48). The Terms exist in both languages (`js/i18n.js`).

---

4. The Operator side, tab by tab

The console tabs (from `operator.html`): Overview, Approvals, Invitations, Users, All Listings, Commodities, Mailbox, Matches, Deals, Analytics, Activity, Scorecard, Help.

- **Overview.** Today's workload, with figures that agree with the database (item 40). Each tile opens the screen where the work is done.
- **Approvals.** Approve or reject a pending registration (items 04, 05).
- **Invitations.** Create and send invitation links (item 01). An invitation link cannot be used twice (item 02).
- **Users.** See every member and suspend an account.
- **All Listings.** Every listing on the platform, with filters (region, role, quantity, date and status). The document column was removed in PR #80, on the reasoning in decision 36.
- **Commodities.** The list members pick from (item 44). Commodities and units are listed alphabetically (item 17).
- **Mailbox.** Every member message arrives here first. The Operator reads it and then forwards it, replies, or sets it aside (items 26, 27, 28). Before forwarding, the Operator edits the message. Contact details (email, web address, phone) are highlighted in red, and the forward is refused while any remain (item 78). The owner gets only the edited text. The original goes to a private activity log that only the Operator can read (item 78, sql 046). A phone number needs at least ten digits to be flagged, so dates and quantities are not flagged. Reason for red highlighting: decision 38 of the batch, "red highlight of contact details, receiver sees only edited text, original kept in Operator-only Activity Log".
- **Matches.** Suggests buy and sell listings that fit together, as scored suggestions for the Operator to act on. Nothing is introduced automatically (item 45).
- **Deals.** A deal file opens by itself the first time the Operator forwards a message about a listing, one per pair of parties (item 70). Its stage, outcome and history are kept, and no entry is ever deleted or rewritten (item 72). Members never see or change deal files (item 71).
- **Analytics.** Week-by-week figures, and deals by stage (items 42, 75).
- **Activity.** The activity log: who did what, and when (item 41). Its details are shown as plain lines, not raw JSON.
- **Scorecard.** Counts of what the Operator recorded in deal files, kept apart by side (item 74). No score and no verdict. Reason: recorded in `docs/research/SCORECARD-DATA-PROTECTION.md`, which is cited in the file header.
- **Help.** The Operator's own help.

---

5. The Terms and the legal design

The current text is `docs/TERMS-3.6-full.md` on branch `terms-3-6`. Version 3.6 adds two sentences to 3.5 (account for one person only; accuracy and authority of statements), and replaces “Jericho Platform” with “MyPlatform” in the Terms text. Version 3.5 replaced the sentence about document checks (decision 37).

The main sections, with the reason recorded where one exists:

1. **Nature of the platform.** Brokers and intermediaries, who may act for both sides. Reason: stated in the Terms and in decision 1 of 2026-10-25, including “in order to protect anonymity and decide what is passed on”.
2. **Private, invitation-only.** Membership is closed. Reason: as in section 1 above.
3. **Access and eligibility.** Professional capacity; the individual’s obligations extend to any company they later control. Reason: decision 6 of 2026-10-25 (“obligations follow a freelancer into any company”).
4. **No verification, no warranty.** The Operators do not verify, endorse or guarantee any participant, listing, document or price.
5. **Own due diligence.** Each member is solely responsible for due diligence, and now also for the accuracy and authority of what they state (3.6).
6. **No professional advice.**
7. **Anonymity and conduct.** Listings are anonymous; no identification attempts; all contact through the Operator; false offers and forged documents are prohibited. Reason: decision 8 of 2026-10-25, prohibited conduct.
8. **Non-circumvention and commission.** The commission is payable whenever a transaction results from an introduction, and the obligation lasts 24 months from the introduction, even if the deal closes outside the platform. The only exception is a principal sending confidential documents directly to the introduced counterparty. Reason: decisions 2 and 3 of 2026-10-25. The legal basis is discussed in `docs/LEGAL_REVIEW_NOTES.md`; this brief does not summarise it.
9. **Confidentiality.** Information obtained through the platform is confidential.
10. **Privacy Notice.** What is collected, why, and who can see it. Decision of 2026-10-26 (Terms 3.2). Placeholders remain for the data controller address, supervisory authority and transfer safeguard (see section 7).
11. **Limitation of liability.** Broad exclusion of loss, with carve-outs for what cannot lawfully be excluded, including fraud and death or personal injury caused by negligence.
12. **Disputes between participants.** The Operators are not a party and accept no responsibility.
13. **Suspension and withdrawal.** Access may be suspended at any time, without reasons.
14. **Changes.** A material change must be accepted before use continues. Continued use after a change takes effect is also treated as acceptance.
15. **Governing law and courts.** English law; exclusive jurisdiction of the DIFC Courts, as an express agreement under Article 14(B) of Dubai Law No. 2 of 2025. Service by email and at the postal address. Reason: decision 4 of 2026-10-25. The DIFC clause has not been verified against the official text in this brief.
16. **The Operators.** The platform is run by one individual, trading under his own name until the operating company is incorporated. The company details are placeholders.

Why the Terms are as they are. Decisions of 2026-10-22 to 2026-10-25 record the reasons: the Operators’ role as intermediary (1), commission agreed per deal (2), commission must not be promised before the introduction (3), English law (4),

acceptance records survive deletion (5), obligations follow the individual into any company (6), the answers on a listing are statements under the Terms (7), prohibited conduct (8). Later decisions added the privacy notice (10-26), the receipt email (decision 43, on `receipt-email-terms`), Terms 3.6 (decision 44), and the owner's wording of the document-check sentence (decision 37).

Known conflicts. The decisions say the company will be incorporated in "Dubai — DMCC or Meydan free zone. Not DIFC" (`docs/AGREED-2026-10-25.md`, "The company"). Section 15 of the Terms, however, names the DIFC Courts. This is not resolved in the repository.

---

6. The back end

Database. Supabase Postgres, with row-level security. The tables created by the migrations are: profiles, invitations, commodities, reference_counters, listings, document_checklist, document_requests, messages, message_forward_log, activity_log, matches, notifications, deals, deal_history, saved_searches, terms_versions, terms_acceptances, email_outbox, email_templates, email_phrases. The full list of migrations is in `sql/` (47 numbered migrations as of this brief, with revert files in `sql/revert/`).

Why a database-level rule. `HANDOFF.md` and the Operator console's rules say that every rule is enforced in the database, not only in the form (decision 22 of 2026-10-25). The reason written down is decision 22's own wording: "enforced in the database, not only in the form". The bypass argument (a browser-only rule can be skipped by calling the API directly) is this brief's reading, not a recorded reason.

Key prohibitions. The checklist (`docs/CHECKLIST.md`) has 80 items, of which 38 are "must not". The strongest ones are: no member reads another member's private data by any route (item 50); a caller with no account reaches only their own invitation token (item 51); the audit log and the Operator feed cannot be written by hand (item 52); nobody creates an account without a valid invitation (item 56); text a member types is shown as characters, never run as code (item 58); a member not approved cannot read the market (item 59). Item 46 (flood limit) is also proven under concurrency with `npm run stress`, because a single-connection test cannot show the race (`docs/CHECKLIST.md`, open questions). The race was found on 2026-10-11, when 24 concurrent posts were all accepted against a limit of 20 (`sql/019` serialises the check per member).

Email. Two separate things (`HANDOFF.md`, "Email: who sends what"): the platform's outbound notifications, through Resend (free tier read from their pricing page on 2026-10-19; the sending domain is not yet verified, so only the owner's own address receives mail); and the owner's own mailbox, decided as Purelymail at $10 a year. The outbox is `email_outbox`, sent by `scripts/send-listing-emails.js` through `.github/workflows/send-emails.yml`. Items 48 and 49 may not be verifiable until the sending domain is verified (`docs/CHECKLIST.md`, open questions).

Sites on Cloudflare Pages. Four sites, each its own Pages project, decided in `docs/AGREED-2026-10-28-cloudflare.md`: - `platform` (the app, at app.myplatform.trade, published from `ci.yml`'s `deploy-cloudflare` job, behind the gate). - `platform-www` (the front page, `ci.yml`'s `deploy-www` job). - `myplatform-demo` (the member demo, `demo-pages.yml`, publishes only on main after its tests

pass). - `myplatform-operator-demo` (the Operator demo, `operator-demo-pages.yml`, publishes only on main after its tests pass). Its setup and teardown are in `HANDOFF.md`. It has not been created yet.

Reason for separate demo projects: decision 42 of `docs/AGREED-2026-11-01-owner-changes.md` (a separate Operator demo, not linked from any public page). The reason for a separate member demo is not recorded.

How a change goes live. 1. A pull request. Work reaches main only through a pull request (`CLAUDE.md`). Each pull request must name what it serves (`scripts/check-pr-purpose.js`, the `purpose.yml` workflow). 2. The CI gates in `ci.yml`: database tests (`sql/tests`, run as a non-root user), stale-render guards, migration lists agree, the Terms members read match the Terms the database holds, action double-submit checks, no leaked member data, the email scan, stress and concurrency, Safari, the checklist, and packaging. 3. The deploy gate (`scripts/check-deploy-gate.js`) fails the build if the publish job is weakened, if a required check is dropped, or if another workflow gains a publish step. Break cases are tested (`scripts/test-deploy-gate.js`). 4. The browser suite (Playwright, `tests/e2e`) and the checklist report (`scripts/checklist-report.js`). A failing item is a failing build, and the report says why. 5. The security grid (`security-grid.yml`) and its picture check (`tests/visual`), with approved reference pictures. 6. The second-opinion review (`review.yml`) by a model that did not write the code. It is an opinion only and cannot fail a build. 7. Database changes are applied to live with `apply-sql.yml`, after the migration has been proven by a revert in the test database. The live database is changed only with the owner's permission for anything that deletes or changes members' data. 8. The owner merges, or delegates the merge.

---

7. Known open points and placeholders

- **Company details.** Section 16 of the Terms has placeholders for the country of incorporation, company registration number, registered office, trading address, and VAT or tax number. The Terms say the company will be incorporated, but it is not yet.
- **Privacy placeholders.** Section 10 has placeholders for the data controller's address, the supervisory authority and its contact, the hosting region, and the transfer safeguard. The retention period is not stated.
- **Company jurisdiction conflict.** The company is to be in Dubai (DMCC or Meydan), but the Terms name English law and the DIFC Courts (see section 5).
- **Operator identity.** The Terms say the platform is operated by one individual, trading under his own name until incorporation. The personal-liability position of that individual is not researched in the repository.
- **Liability clause.** No financial cap. Negligence is not separately addressed. Reason for the current wording: not recorded in the decisions.
- **External reviews.** Three reviews of Terms 3.6 are on branch `claude/great-allen-5xl0gm` under `docs/terms-reviews/`: ChatGPT, Grok, and Mistral. The Grok review has been analysed; the other two have not, and nothing from any of them is adopted yet.
- **Items still open in `HANDOFF.md`.** Among them: the sending domain for Resend; the demo and Operator-demo Cloudflare teardown proofs; the hygiene job's queue behaviour; the films, which are not recorded because the owner has not approved the stills; and the Terms version Sunday decision.

- **Email confirmation.** Changing an email address needs a confirmation the project does not send (`HANDOFF.md`).
- **Origin disclosure.** Browse returns the origin in full, which the checklist records as "a product decision, open as item 2 in HANDOFF.md".
- **Film and trailer.** The films are not recorded yet. The Spanish trailer is kept outside the repository, awaiting a native-Spanish check.

---

8. Questions for the reviewing AI

Please answer each with the reasoning, and say where you are relying on a guess.

1. Is the Operator email (item 79) redundant with the Operator mailbox, or does it add a real signal? What does it reveal about timing that a member's behaviour could exploit?
2. The red highlight of contact details (item 78) is a regex. What contact details does it miss? Which legitimate text does it flag?
3. Browse shows the poster's role and documents line. Does that line, combined with the listing's commodity and origin, allow a counterparty to identify the poster? What is the minimum combination that identifies someone?
4. Commission before introduction: the film script and the decisions state this order, but the decisions also say "When both agree, the Operator makes the introduction". Which order is intended, and where could a member read it differently?
5. Non-circumvention lasts 24 months from the introduction, but the Terms also allow the Operator to suspend access at any time. Does suspension end the commission obligation, and is that stated?
6. The platform forbids automatic introductions, but it produces scored matches. Could the scoring be a hidden introduction? What stops an Operator's habit from becoming one?
7. The deal file records outcomes "by side". Could the Scorecard reveal a member's identity by deduction across small counts? Is there a minimum count?
8. Test accounts use reserved domains as a marker. Could a real member use one of those domains and be silently excluded from emails? Is that a real risk?
9. Items 48 and 49 may not be verifiable until the sending domain is verified. Is there a path where emails are never sent and nobody notices?
10. Four Cloudflare Pages projects are planned, with the demo projects published from main. Could a demo ever expose live data, and what prevents it beyond the build's secret scan?
11. The Operator's sign-in and the member's sign-in share one page. Is there a way for a member to reach an Operator screen by URL? Which checks stop it, and which of them are only in the browser?
12. Which of the 80 checklist items would still pass if the database rules were removed, and which would fail? Which "must not" items are proven only by the browser?
13. The Terms say the individual's obligations extend to any company they later form. Is that enforceable, and what would change it?
14. The receipt email (decision 43) and the Terms 3.6 change both depend on the signing record. What happens to a member who signed 3.5 but has not seen 3.6?

15. The design rests on the Operator being one human. What breaks if there are two, or if the Operator is absent for a week?